AI risk scenarios through NIST AI RMF

The reference architecture run through six change events: Govern, Map, Measure, Manage

Enterprise Architecture · 4 November 2026

[Insert official FIP signature and Canada wordmark]

Six change events cross the trust boundary

- The reference architecture says where controls sit. These walkthroughs show them working.
- Each scenario is something that changes: a model, a tool, a knowledge source, who the system acts for, what it may change, and what happens when it fails.
- Each gets a diagram of its gate, then a table that runs NIST Govern, Map, Measure and Manage against it.
- Every table ends in evidence we keep and an owner, so an auditor can trace a decision.
- You asked for four of these. I added two: actions that change things, and incidents. Swap them if they are not the right ones.

How each scenario is built

- 1 Trigger: the cause.
- 2 Tier: sets the depth.
- 3 Run the four NIST functions.
- 4 Keep evidence; name the owner.
- 5 Say when to run it again.

Source: Enterprise Architecture. Judgment: this is my read, not a published standard.

Each scenario names its trigger and its risks

Scenario	Trigger	What crosses the boundary	Main risks	Usual tier
1 New model or version	A provider releases one, or we switch	A model we do not control enters the path	Confabulation; bias; value chain; security	A to D
2 New tool or MCP server	A team asks to connect a system	Outside text and actions enter and leave	Information security; prompt injection	B to D
3 New RAG source	A team wants answers from its documents	Content and its access rules enter the index	Data privacy; confabulation; vector weaknesses	B to D
4 User-to-system permissions	An agent must act for a user	A user's authority passes to a system	Information security; excessive agency; privacy	B to D
5 Actions that change things	A tool can write, send or delete	The system changes the world	Human-AI configuration; excessive agency	C to D
6 Incident	A leak, a bad answer or misuse	Normal operation breaks	All of the above	Any

Tiers A to D are from the risk addendum. Risks follow NIST AI 600-1 and OWASP LLM Top 10 (2025). Judgment: this is my read, not a published standard.

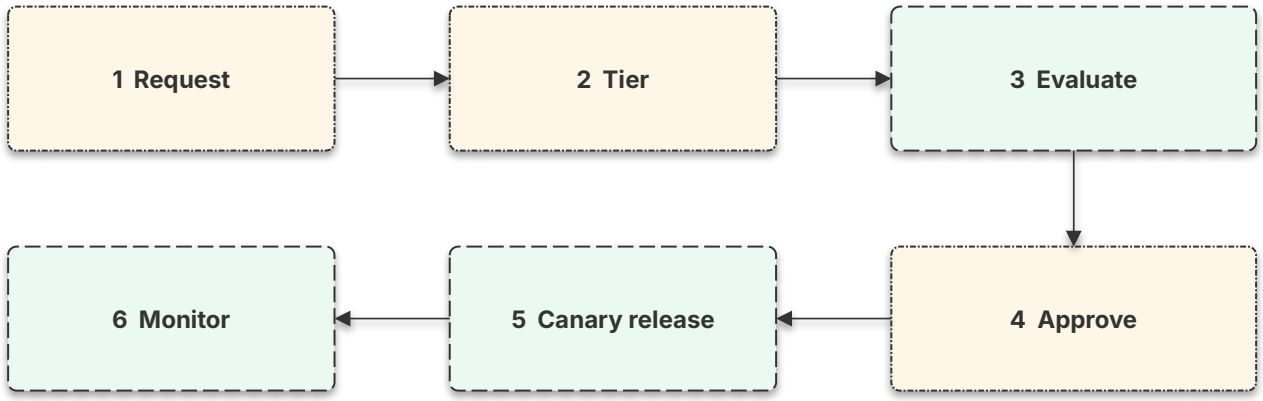
1

Letting things in

A new model, a new tool and a new knowledge source each enter through one gate.

MY READ

A new model enters through one gate



1 Request: the model owner names the provider, version, region and intended use cases.

2 Tier: the highest tier among the use cases that would use it sets the depth of review.

3 Evaluate: our own test set against the current model, plus subgroup, injection and privacy tests.

4 Approve: governance board for Tier C and D; the model owner for Tier A and B.

5 Canary: a small group first; the version is pinned at the gateway; rollback is ready.

6 Monitor: quality, cost and incidents; go back to step 3 if the provider changes the model.

Person Decides Check Or Control

Figure 1 — New model introduction gate

Why a gate for models

— A hosted model can change under us. The gate makes sure a change is seen, tested and approved.

— Our own test set is the point. Provider benchmarks do not know our documents, languages or clients.

— Pinning the version at the gateway means a provider update cannot reach users unreviewed.

Source: Enterprise Architecture. Judgment: this is my read, not a published standard.

SCENARIO 1: NEW MODEL

New model: what each NIST function asks

NIST function	What we do	Evidence kept	Owner
Govern	Only listed providers; a named model owner; the governance board approves for Tier C and D	Approved-provider list; decision record	AI governance board
Map	State intended use, data classes sent, hosting region and which existing use cases are affected	Intake note; data-flow sketch	Model owner
Measure	Run our test set against the current model: cited accuracy, subgroup and language results, injection suite, privacy leak tests, cost, speed	Evaluation report	Model owner; security
Manage	Pin the version; release to a small group; keep rollback ready; re-run on any provider change	Gateway configuration; canary results; change log	CIO

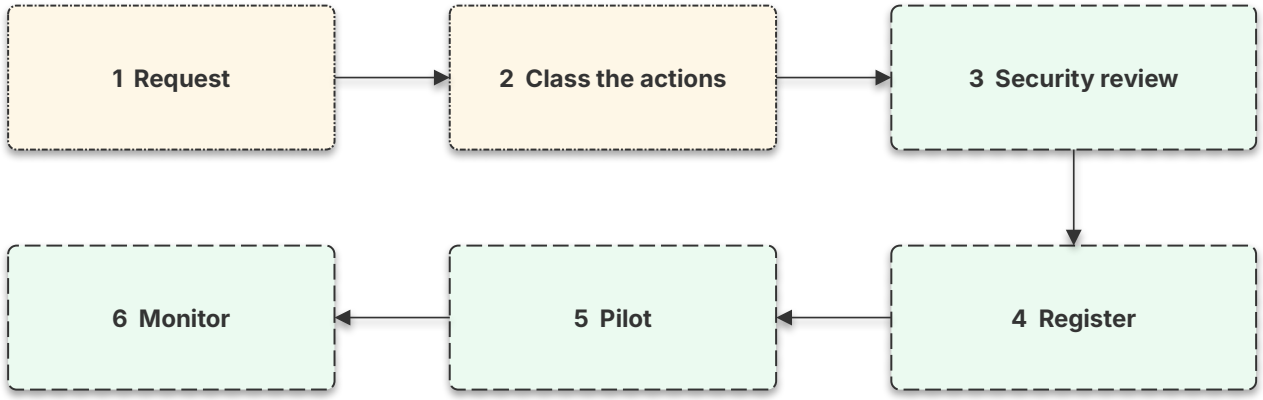
Where the standard points

— NIST AI 600-1 suggests keeping an inventory of third parties and an approved list of providers, and monitoring after release (as summarized by a secondary source).

Sources: NIST AI RMF 1.0 (Jan 2023); NIST AI 600-1 (Jul 2024). Steps: my read.

MY READ

A new tool is vetted before the gateway lists it



1 Request: the tool owner names the server, who runs it, and what each tool can read or change.

2 Class: every action is read, draft or change; change actions raise the tier.

3 Review: security treats tool descriptions and results as untrusted text and checks token audience.

4 Register: the gateway lists the tool only with an owner, narrow scopes and a kill switch.

5 Pilot: a small group first; test injection through tool results; watch denied calls.

6 Monitor: re-review when the server, its tool list or a description changes.

Person Decides Check Or Control

Figure 2 — New tool connection gate

Why tools need their own gate

— Anything a tool returns goes into the model's context, so a tool is also a way to inject instructions.

— MCP is not secure by default. Authorization is optional in the protocol, so our gateway must require it.

— A change to a tool's description can change what the model does, so it counts as a change.

Sources: MCP security guidance and authorization specification, via secondary summaries. Judgment: this is my read, not a published standard.

SCENARIO 2: NEW TOOL

New tool: what each NIST function asks

NIST function	What we do	Evidence kept	Owner
Govern	The tool registry is the only way a tool is listed; each tool has an owner and a class (read, draft, change)	Registry entry	Tool owner
Map	List what the tool can read and change, what text it returns, and whether it reaches outside our boundary	Tool profile	Solution architect
Measure	Review descriptions as untrusted input; test injection through results; check token audience and scopes; test failure behaviour	Security test report	Security
Manage	Pilot first; per-tool kill switch at the gateway; re-review when the server or its description changes	Pilot results; change alerts	CIO

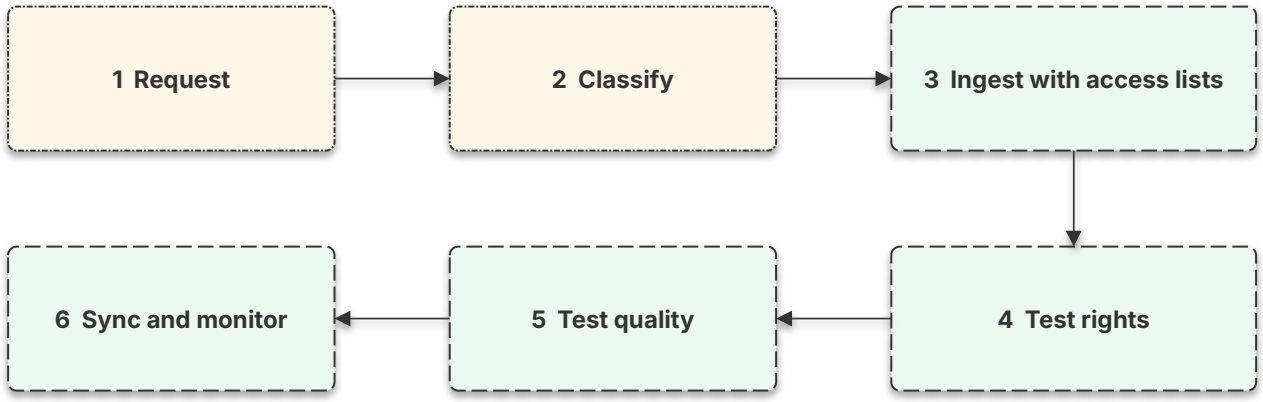
Why the review is strict

— Researchers have logged incidents such as cross-tenant data exposure in early MCP deployments. OWASP lists prompt injection first and excessive agency sixth (2025).

Sources: OWASP Top 10 for LLM Applications 2025; secondary summaries of MCP security guidance. Steps: my read.

MY READ

A new source is tested before it is indexed



1 Request: the data owner names the source, its classification and who may read what.

2 Classify: sources above the tier limit, or with no clear owner, are not indexed.

3 Ingest: every chunk carries its source's access list; the index holds no open copies.

4 Test rights: people who must not see an item try to retrieve it, directly and by rewording.

5 Test quality: citations point to the right passage, answers match the source, content is fresh.

6 Sync: permissions and deletions re-sync on a schedule; a failed sync raises an alert.

Person Decides Check Or Control

Figure 3 — New knowledge source gate

Where the rights check lives

— Enforce access in the retrieval query. After generation is too late: the model has read it.

— OWASP added vector and embedding weaknesses in 2025.

— Stale permissions are the quiet failure: a person leaves a group and still retrieves its documents.

Sources: OWASP Top 10 for LLM Applications 2025; Microsoft Learn, Azure AI Search document-level access; secondary RAG guidance.
Judgment: this is my read, not a published standard.

SCENARIO 3: NEW RAG SOURCE

New source: what each NIST function asks

NIST function	What we do	Evidence kept	Owner
Govern	Each source has a data owner and a classification; sources above the tier limit are not indexed	Source register	Data owner
Map	Record who may read what, where the access rules live and how often they change	Access model note	Data architect
Measure	Test with people who must not see items; check citation accuracy, freshness and retrieval quality; repeat after any connector or chunking change	Test results	Model owner; privacy
Manage	Sync permissions on a schedule; remove deleted items; alert on a failed sync	Sync log; alerts	CIO

Link to the earlier decks

— This is the "index, do not copy" principle from the reference architecture, written as steps. Personal information also triggers the privacy review in the risk addendum.

Sources: OWASP Top 10 for LLM Applications 2025; secondary RAG guidance. Steps: my read.

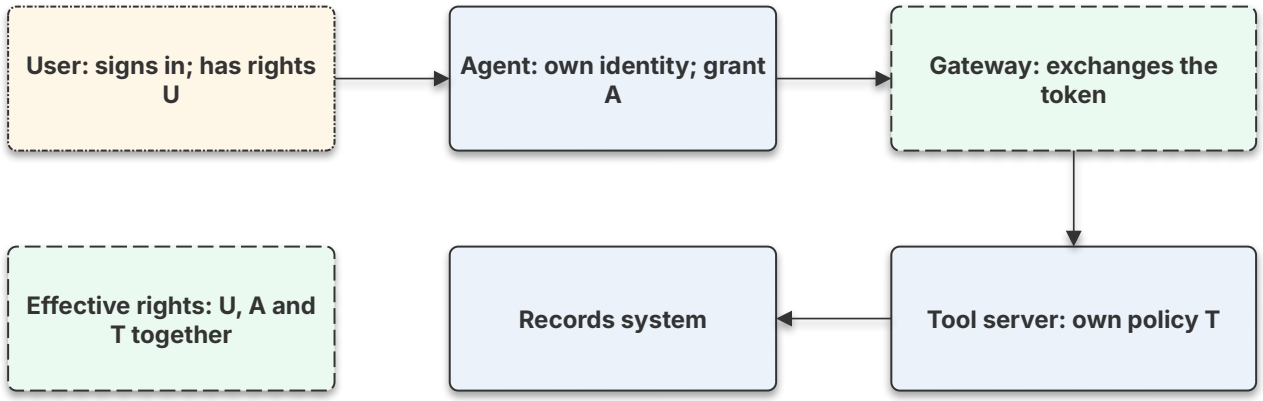
2

Authority and action

How much the system may do for a user, and what it may change.

MY READ

The system acts with a subset of the user's rights



The effective rights are the overlap of three sets: the user's (U), the agent's grant (A) and the tool's own (T).

The gateway swaps the user's token for a new, short-lived one whose audience is this one tool.

No token passthrough. The MCP authorization specification forbids forwarding a token to another service.

The new token names both the user and the agent, so the audit trail shows who asked and who acted.

Rights are checked on every call, so a role change takes effect on the next call, not the next sign-in.

Person Decides System Component Check Or Control

Figure 4 — Delegated permissions through the gateway

Why a subset, not a copy

— If the system held everything the user can do, one injected instruction could do all of it.

— Token exchange (RFC 8693) is built for this: one token in, a narrower one for a different audience out.

— The leftmost box is the test: if the system can do something outside the overlap, the design is wrong.

Sources: MCP authorization spec and RFC 8693, via secondary summaries (Arcjet, Gravitee). Judgment: this is my read, not a published standard.

SCENARIO 4: USER-TO-SYSTEM PERMISSIONS

Four ways to delegate; one keeps rights narrow

Design	How it works	Weakness	Verdict
Shared service account	The system reads everything through one broad identity	Anyone can reach what the account can; the audit shows only the account	Avoid
Token passthrough	The system forwards the user's own token to the tool	A token meant for one service is used at another; the MCP specification forbids it	Not allowed
Impersonation	The system appears to be the user	The audit cannot tell the user from the system	Legacy only; short-lived
Token exchange, downscoped	The gateway swaps the user's token for a narrow one per tool and records user and agent	More set-up; every tool must accept the new token	Preferred

Status

— The first three weaknesses and the "not allowed" verdict come from the MCP authorization specification and OAuth guidance. "Preferred" is my recommendation.

Sources: MCP authorization specification and RFC 8693, via secondary summaries. Judgment: this is my read, not a published standard.

Delegation: what each NIST function asks

NIST function	What we do	Evidence kept	Owner
Govern	The system never holds more than the user and never more than the task needs; every agent has its own identity	Policy; agent register	Chief security officer
Map	For each tool, list user roles, the scopes it offers and the smallest scope each task needs	Scope matrix	Solution architect
Measure	Test with low-rights users: try to read or change what they cannot; test stale rights after a role change; test confused-deputy cases	Test results	Security
Manage	Short-lived tokens; re-check rights on every call; alert on denied calls; revoke an agent's grant at the gateway	Gateway logs; alerts	CIO

Why this scenario rates High

— Excessive agency (OWASP LLM06) and information disclosure (LLM02) both come from the system holding more authority than the task needs.

Sources: OWASP Top 10 for LLM Applications 2025; NIST AI RMF 1.0 (Jan 2023); NIST AI 600-1 (Jul 2024). Steps: my read.

Actions are classed by what they can change

Class	Example	Rule
Read	Look up a case; search documents	Allowed within the user's rights; logged
Draft	Prepare a reply or a form	Allowed; a person reviews it before it leaves
Change, reversible	Update a field; add a note	A person approves each change; the change is logged with an undo
Change, hard to reverse	Send to a client; delete; pay	A person approves each action; Tier D adds a second approver
Out of bounds	Decide a client's outcome with no human sign-off	Not offered as a tool

Status

— Keeping a person in the loop for anything that writes, sends or deletes is common MCP guidance. The classes and the second approver for Tier D are my proposal.

Sources: secondary summaries of MCP security guidance; Directive on Automated Decision-Making for the final-decision rule at higher impact. Judgment: this is my read, not a published standard.

Actions: what each NIST function asks

NIST function	What we do	Evidence kept	Owner
Govern	Change tools need a named owner and governance board approval; the action classes are policy	Policy; registry class	AI governance board
Map	Class every tool action; list what each could damage and who is affected	Action inventory	Tool owner
Measure	Test that approval cannot be skipped, including by text injected through a document or tool result; test undo	Test report	Security
Manage	Track approval and override rates; review a sample each month; keep a kill switch per tool	Monthly review notes	Program owner

Watch the override rate

— A sudden rise or fall can mean people stopped reading the approvals, or stopped trusting the tool. Both need a look.

Sources: NIST AI RMF 1.0 (Jan 2023); NIST AI 600-1 (Jul 2024) (human-AI configuration risk). Steps: my read.

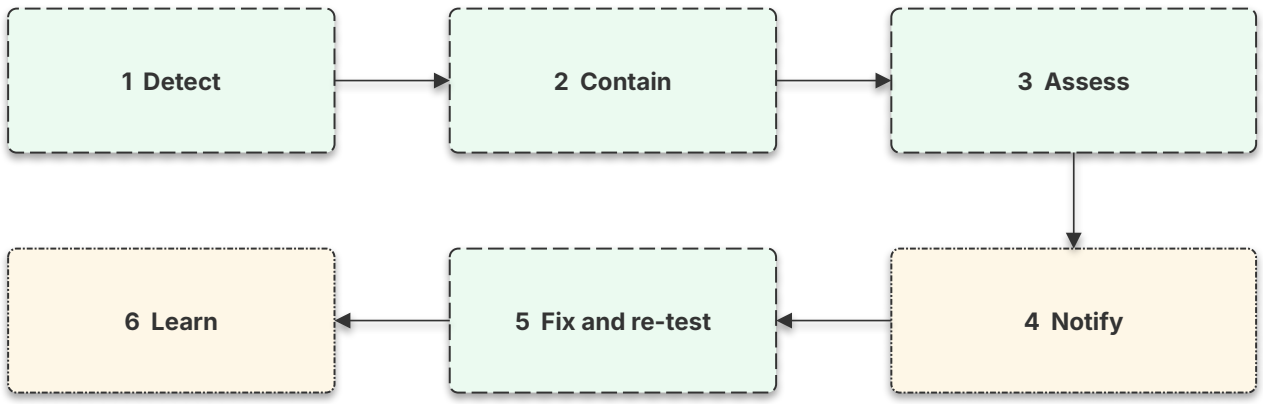
3

When it goes wrong

An incident path that starts at the gateway, and the evidence each scenario leaves.

MY READ

Incident response starts at the gateway



1 Detect: an alert, a user report or a log review shows a bad answer, a leak or misuse.

2 Contain: switch off the tool, source or model route at the gateway, with no release needed.

3 Assess: replay from the logs to find which users, data and answers were affected.

4 Notify: privacy, security and program owners, following the departmental breach procedure.

5 Fix: correct the cause, then re-run the scenario tests that should have caught it.

6 Learn: add the case to the test set, reassess the tier and update the register.

Check Or Control Person Decides

Figure 5 — AI incident response path

Why the gateway matters here

— One control point means one switch. Containment does not wait for a release.

— Logs of every call let us say what was exposed, not guess.

— Notification follows the departmental procedure. This deck does not replace it.

Source: Enterprise Architecture. Judgment: this is my read, not a published standard.

Incidents: what each NIST function asks

NIST function	What we do	Evidence kept	Owner
Govern	Incident roles and severity levels are agreed before anything happens; AI incidents use the departmental process	Incident procedure; contact list	Chief security officer
Map	Know which use cases share the failing part: the model, the tool or the source	Component dependency list	Solution architect
Measure	Replay from logs; measure who and what was exposed; test the fix against the failing case	Incident record	Incident lead
Manage	Contain at the gateway; fix; re-test; record; update tests and tier	Updated tests; register entry	CIO; program owner

Practice it

— Run a table-top exercise each quarter on a scenario from this deck. Start with a restricted passage reaching the wrong user.

Sources: NIST AI RMF 1.0 (Jan 2023); NIST AI 600-1 (Jul 2024). Steps: my read.

EVIDENCE

Every scenario leaves evidence and a re-run trigger

Scenario	Gate owner	Evidence kept	Run it again when
1 New model	Model owner; governance board	Evaluation report; provider list entry	The provider changes the model, or a use case changes scope
2 New tool	Tool owner; security	Registry entry; security test report	The tool or its description changes, or an action is added
3 New source	Data owner	Source register; rights-test results	Access rules change, or the connector or chunking changes
4 Delegation	Chief security officer	Scope matrix; low-rights test results	The role model changes, or a tool adds scopes
5 Actions	Program owner	Action inventory; approval and override rates	A new action class appears, or overrides shift sharply
6 Incident	Incident lead	Incident record; updated tests	After every incident, and quarterly for the exercise

> **One register**
>
> — All evidence lives in one place, tied to the use-case registry, so the governance board can see the whole portfolio.

Source: Enterprise Architecture. Judgment: this is my read, not a published standard.

DECISIONS

What the Board needs to decide

Proposed defaults

— Every change event goes through a named gate

— Evidence is kept in one register

— Tokens are narrowed, never passed on

— Rights are enforced in the retrieval query

— Changes need a person's approval

Board decides

— Minimum test set and pass marks for each tier

— Who approves a new provider

— Whether Tier D change actions need two approvers

— Classification limit for what may be indexed

— Incident severity levels and who is told

Source: Enterprise Architecture. Judgment: this is my read, not a published standard.

Sources and further reading

Standards and frameworks

NIST AI 600-1, Generative AI Profile
Twelve generative AI risks and actions

OWASP Top 10 for LLM Applications 2025 (summary)
Prompt injection, excessive agency, vectors

MCP authorization specification
Not opened; known from summaries

OAuth Token Exchange, RFC 8693
Narrower token for another audience

Practice and explanation

MCP security best practices (summary)
Untrusted tool text; human approval

Agent identity and on-behalf-of
Subject and actor claims

Azure AI Search document-level access
Security trimming in retrieval

Permissions in enterprise RAG
Enforce at retrieval, not the prompt

Links taken from search results on 4 November 2026. Most are secondary summaries; check the primary text before quoting.